

Removing Self-Signed RDP Certificates

 technet239.rssing.com/chan-4753999/article25518.html

Hello all. Jacob Lavender here for the Ask PFE Platforms team to talk a little about a common scenario that I'm often presented with – How to rid Windows machines of the self-signed remote desktop client certificate that is created on Windows clients and servers?

Prior to diving in, let me just state that we will not be discussing in great depth why Windows machines have a self-signed certificate within this article. At a basic level, it is due to the necessity of having a certificate to support Network Level Authentication (NLA), which is an advanced security feature designed for pre-authentication intended to protect machines from a Denial-of-Service (DoS) attacks via the RDP protocol.

Kristin Griffin has published a great article which can discuss NLA in greater detail:

<https://technet.microsoft.com/en-us/library/hh750380.aspx?f=255&MSPPErr=-2147217396>

At the end of the day, we want NLA, and many organization's cyber security guidelines mandate it. However, those same guidelines often mandate that self-signed certificates are not allowed within the Remote Desktop certificate store.

So, what are we going to cover:

Topic #1: Why do my Windows machines continuously regenerate this certificate despite having been removed?

Topic #2: How can I remove the self-signed certificate from machines across my enterprise?

Topic #3: How can I prevent the certificate from being regenerated upon remote desktop connection or reboot?

Topic #4: How can I automate the permissions on the registry key?

Topic #5: How can I properly deploy certificates to my Windows machines?

Tested on:

- Windows Server 2016
- Windows Server 2012 R2
- Windows Server 2008 R2 (Requires PowerShell 3.0)
- Windows 10
- Windows 8.1

- Windows 7 (Requires PowerShell 3.0)

PowerShell update for Windows Server 2008 R2 and Windows 7:

<https://blogs.technet.microsoft.com/heyscriptingguy/2013/06/02/weekend-scripter-install-powershell-3-0-on-windows-7/>

Make sure to read **Topic #5** prior to taking any action internally to fully understand the entire scope of our discussion within this post.

And with that, now let's dive in.

Topic #1: Why do my Windows machines continuously regenerate this certificate despite having been removed?

Windows machines automatically generate a self-signed certificate for use with the Remote Desktop protocol. This is by design as it is intended to increase the overall security posture of all machines within the enterprise which have Remote Desktop enabled.

Simply disabling Remote Desktop on a machine will not prevent the machine from regenerating the self-signed certificate.

I have had numerous clients bring this issue forward due to many security guidelines and scans flagging this as a finding. However, the machines are in fact more secure with the self-signed certificate than without due to the intended purpose. Most security guidelines advise to avoid the use of a self-signed certificate generated by each individual machine as other machines on the network have no means to trust this certificate and validate that the machine is in fact that machine.

However, remember that we are discussing the use of the self-signed certificate within the context of NLA, not within Public Key Infrastructure (PKI). Fortunately, we'll be addressing that component of the complete solution within **Topic #5**.

Topic #2: How can I remove the self-signed certificate from my machines across my enterprise?

Fortunately, this is a simple task. We have PowerShell to answer our needs on this front. A sample script can be downloaded here to remove self-signed certificates from the Remote Desktop certificates store:

<https://gallery.technet.microsoft.com/Remove-Self-Signed-RDP-00413912?redir=0>

PowerShell 3.0 or higher is required.

Note: Do not run this script on internal Certificate Authorities which have issued their own Remote Desktop Authentication certificate.

This script can be configured as a startup script via GPO. Depending on your domain's PowerShell Execution policy, you may need to configure the Script Parameters to include - ***ExecutionPolicy ByPass***.

You will find that some clients will immediately generate a new self-signed certificate. In short, configuring this as a startup script alone will likely not eliminate the self-signed certificate from returning.

You will need to determine if you wish to leave the startup script in place or remove it from the GPO once you have completed this.

Other deployment methods, such as System Center Configuration Manager, are also great options and should be considered.

Additionally, now that the certificate has been removed, Remote Desktop connections to these machines will likely fail as NLA will not have a certificate to use. This is where **Topic #5** becomes very critical.

Topic #3: How can I prevent the certificate from being regenerated on remote desktop connection or reboot?

As we have discussed, Windows by design generates a self-signed certificate. The machines local System account performs this function. To prevent the certificate from being generated again, we can simply deny the System account from having the necessary permission to generate the certificate. To accomplish this, we can simply deny the right within the registry:

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\SystemCertificates\RemoteDesktopCertificates

The permissions can be edited manually, or via an automated means (see **Topic #4**).

Prior to modifying the registry, ensure that you have a valid backup of the registry and that you perform the necessary testing within a lab to gain greater insight into how modifying the registry within your image will impact operations.

Modifying the registry can result in system failure so ensure that you have a proper plan to recover should a mistake be made. The settings within this article are non-destructive, however they can impact operations such as providing remote support to users.

To manually edit the permissions on this key start by right clicking the key and selecting Permissions:

- At the permissions window, select the **Advanced** radio button, then select the **Add** radio button.
- At the Permission Entry for Certificates window, select the **Select a principal** option.
- At the Select User, Computer, Service Account, or Group window, modify the location to search for the account to the local computer.

Having returned to the Select User or Group screen, type **system**, and then select **Check Names**. This should resolve the account to the local machine account object. Now select **OK**.

- Having returned to the Permission Entry for Certificate, change the ACL Type to **Deny**.
- Now, select **Show advanced permissions**.

Now that the advanced permissions are available, select **Create Subkey**.

Each certificate on the machine is a subkey within the Certificates key in the registry. By denying the System account object the Create Subkey permission, we are preventing the System account to create the certificate.

Now, what is the impact of having configured the Certificates registry key ACL in this manner? We may see a system event (Event ID 1057) in the system's event log. It will simply be an indication that the System account was unable to create the subkey due to Access Denied:

Topic #4: How can I automate the permissions on the registry key?

To address this, we can utilize a GPO which will set the ACL on the key. Simply add the registry key to an appropriate GPO which is targeted at the machines in the enterprise that you wish to implement this change. As an example, I have made this addition to my Workstation Baseline GPO in my lab as I want this to be configured on all Windows clients:

It's important to note that this GPO will create an entry on the key's ACL which will remain even if the GPO is removed. If you need to modify the ACL in the future, you will need to ensure to grant the permission back.

Alternatively, we could use PowerShell to configure this on the key directly. You can locate a sample script at the following location:

<https://gallery.technet.microsoft.com/Remove-Self-Signed-RDP-00413912?redir=0>

This same sample script can be modified to correct any permissions on the key/sub-keys. Again, have good backups of the registry and perform ample testing prior to utilizing this in a production environment. It's critical to understand how this will impact your operations.

Topic #5: How can I properly deploy certificates to my Windows machines?

For this discussion, we're going to assume that you have an internal CA. Why? With an internal issuing CA we are able to automate the process of deploying certificates for the purpose of Remote Desktop.

Utilizing an external CA would likely:

- Be cost prohibitive due to the cost of obtaining certificates from public certificate issuers, or
- Be extremely time intensive to obtain certificate requests from all machines and submitting them manually.

So, we should begin by **configuring the certificate template on the issuing CA**. If you do not already have a certificate template published, duplicate the Computer certificate template and update the name of the template on the General tab.

PFE Pro Tip: Ensure that the template name is useful. I always name published templates with the word "published" in the name; example:

"Published RDP Certificate Template <Date>"

Certificate Template

While all settings for the template are beyond the scope of this document, here are the critical items:

- Update the name to be of value within the enterprise (remember to make the naming convention sustainable over time so it grows with your environment).
- Ensure the validity period is aligned with your enterprise PKI requirements. A discussion with Cyber Security might be required for this to be defined.
- Ensure that the Extensions for both Client Authentication and Server Authentication are present.
- Add the following Remote Desktop Authentication Application policies extension:
 - On the **Extensions** tab, select **Application Policies** and then select **Edit**.
 - At the Edit Application Policies Extensions window, select **Add**.
 - On the Add Application Policy window, select **New**.
 - At the New Application Policy windows, label the Application Policies Extension **Remote Desktop Authentication**. The Object identifier (OID) should be **1.3.6.1.4.1.311.54.1.2**.

- Ensure that the appropriate group has been set with **Autoenroll = Allow** on the Security tab. You can use Domain Computers if the GPO used within this guide will target the entire domain. Alternatively, you can specify a security group and grant the Autoenroll permission to ensure that only the desired machines receive this certificate.
- On the Subject Name tab, ensure that **Build from this Active Directory information**, and select the appropriate Subject Name Format – typically Common Name works fine. Ensure to also include the DNS name as an alternative name.
- If you require an administrator to approve these certificates, that can be configured on the Issuance Requirements tab.

Default Certificate Template GPO

We need to now deploy the certificate to our clients. This is managed in two different settings.

- Define the client PKI autoenrollment.
- Define the default Remote Desktop services template for the client.

Let's begin by defining the client PKI autoenrollment policy. This is performed via a GPO which is then targeted to the clients within the enterprise which this effects. The following settings are required:

Computer Configuration > Policies > Windows Settings > Security Settings > Public Key Policies

- **Certificate Services Client – Certificate Enrollment Policy = Enabled**
- **Certificate Services Client – Auto-Enrollment = Enabled**
 - **Enable** Renew expired certificates, update pending certificates, and remove revoked certificates
 - **Enable** Update certificates that use certificate templates

Now that we have the clients configured for Auto-Enrollment, let's configure the RDP Default Template. The following settings are required:

Computer Configuration > Policies > Administrative Templates > Windows Components > Remote Desktop Services > Remote Desktop Session Host > Security

Server authentication certificate template = Enabled

Define the Certificate Template Name. You must use the short name of the template that was published on the CA. This is the Template Name as defined on the CA. This is NOT the Template Display Name. See the image below:

Validation

After successfully deploying the certificate to the machine, we should now see an Event 1063 in the System event log:

Finally, you should now be able to RDP to clients with NLA and they should utilize the assigned certificate.

Note: I have seen where if Remote Desktop was previously enabled, it must be disabled and then re-enabled. Again, perform proper testing in your environment to ensure you have a valid action plan on how to address any variations.